

Level 4 server to a Level 1 PLC—to present a unique security token (digital certificate), we move beyond simple passwords. This validation of public and private key pairs ensures that a device is truly what it claims to be, effectively denying access to any ‘spoofed’ or rogue hardware that attempts to join the plant network.

Delay: By applying the Purdue Model and enforcing strong network segmentation across layers, this step aims to slow down the lateral movement of threats within the environment. Using zones, conduits, firewalls, and access controls, communication between layers is tightly regulated, ensuring that any potential compromise is contained and prevented from rapidly propagating across the network.

Defend: This is the final safety net. It operates under the principle of ‘assume breach’, ensuring that even if an attacker bypasses the first four D’s, we have a robust resilience plan to neutralise the threat. This involves immediate incident response (IR) triggered by automated playbooks that isolate affected segments—such as a single production cell—to prevent lateral movement. Furthermore, ‘gold standard’ backups of PLC logic and SCADA configurations are maintained, supported by validated runbooks that allow us to restore operations to a known-secure state with minimal downtime.

Overall, a layered Purdue architecture combined with a defense-in-depth (D5) strategy helps significantly reduce risk exposure by enforcing segmentation, controlled communication, and multiple layers of security. By further leveraging AI-driven analytics for threat detection and anomaly identification, organisations can adopt a more proactive approach in identifying potential issues early.

However, to ensure that these controls are consistently implemented, validated, and aligned with industry best practices, it is essential to anchor this approach within established standards

and compliance frameworks. These frameworks provide the necessary guidelines, benchmarks, and governance mechanisms to sustain a secure and resilient operational environment.

Standards and compliance

While ISO/IEC 27001 remains the gold standard for Information Security Management Systems (ISMS) and is essential for establishing baseline customer trust, it is primarily IT-centric. For organisations operating in the global market, we must navigate a ‘compliance mosaic’ where regional standards—such as IRAP (Australia), OSPAR (Singapore), and KISA-ISMS (Korea)—act as mandatory gateways for local government and financial sector bids.

In the specialised domains of OT and IoT, general IT standards alone are insufficient due to legacy protocols, safety-critical operations, and long asset lifecycles. We address this by combining NIST SP 800-82 Revision 3, which provides prescriptive guidance on ICS network segmentation, remote access control, continuous monitoring, and incident response, with ISA/IEC 62443.

While NIST provides guidance and best practices for implementing cybersecurity controls, ISA/IEC 62443 establishes a comprehensive, OT-specific framework of security requirements across asset owners, system integrators, and product suppliers. It addresses key aspects such as secure system design, zone-and-conduit segmentation, component-level hardening, and lifecycle risk management.

By aligning with both frameworks, organisations can operationalise critical controls such as network segmentation,

least-privilege access, secure remote connectivity, and supplier risk management. This ensures that the OT security posture is not only technically robust, but also enforceable, auditable, and resilient in real-world industrial environments.

To achieve true industrial resilience, we must simultaneously pull three critical levers: continuous awareness, shared accountability that transcends the security silo, and unwavering alignment with global industry guardrails.

The widespread adoption of AI presents a significant opportunity to shift from reactive defence to a proactive security posture—anticipating and addressing threats before they materialise. However, this transition is as much cultural as it is technological. Many organisations remain confined to a reactive, response-driven cycle. True resilience requires institutionalising a security-first mindset, where risk management is embedded into the operating model and reinforced at every decision point across the enterprise.

This cultural ownership must manifest through technical rigour. Closing architectural gaps via a disciplined implementation of the Purdue Enterprise Reference Architecture (PERA) is an immediate priority. When bolstered by the regulatory depth of IEC 62443 and NIST 800-82, this layered defence provides the structural integrity required to secure our critical IT/OT touchpoints.

By ensuring a Human-in-the-Loop approach to critical decision-making and engineering systems with quantum-resilient security principles, we establish a security posture that is not only robust today but sustainable as a long-term strategic advantage. **END** 🐧

By: T. Sharath Babu

The author is a fractional CTO, and strategic advisor specializing in IoT/OT Cybersecurity, and Insurtech ecosystems.

Disclaimer: The views expressed by the author are his own and in no way represent or reflect the views of the organisation he is associated with.